

Table of Contents

1. Scope and assessment basis
2. Methods and evidence set
3. Results overview
4. Control assessment detail
5. Formal findings
6. Limitations and handoff to risk analysis

[Top](#) | [Bottom](#) | [TOC](#)

TRACER Security Controls Assessment Case Study

Selected control review for a fictional RMF-aligned system

Prepared by Mallory Davis

System	TRACER - Training Records and Compliance Evidence Repository
Fictional organization	Arclight Mission Systems
Prepared by	Mallory Davis
Assessment purpose	Demonstrate how selected controls are examined, tested, and converted into findings that support risk analysis and remediation planning.
Status	Fictional portfolio work sample. Not an official security assessment report.

Assessment standard: The document uses Examine, Interview, and Test as the assessment methods. Status labels are based on available case-study evidence, not on a formal assessor determination.

1. Scope and assessment basis [Back to TOC](#)

This assessment reviews selected control areas that directly affect TRACER access, monitoring, vulnerability response, and incident readiness. It is designed to show how control statements become evidence expectations and how evidence gaps become findings.

- Reference approach: NIST SP 800-53A assessment logic applied in a simplified portfolio format.
- System context: TRACER SSP Case Study.
- Assessment result linkage: findings are carried into the Risk Assessment Report and POA&M.

2. Methods and evidence set Back to TOC

Method	How it is used in this case study
Examine	Review policies, system descriptions, export files, ticket history, scan summaries, and prior tabletop notes.
Interview	Clarify workflow ownership, review cadence, privilege assignment, and escalation expectations.
Test	Validate whether selected logs, role settings, or evidence records support the stated control behavior.

Evidence item	Assessment use
Access request sample	Checks approval path and role traceability.
Privileged access roster	Supports review of administrative account scope.
Break-glass account record	Tests whether exceptional access is controlled and evidenced.
Log review tracker	Checks audit-review cadence and reviewer attribution.
Vulnerability scan summary	Identifies open high findings and aging.
Tabletop action log	Evaluates whether incident readiness follow-up is tracked to closure.

3. Results overview Back to TOC

Result type	Count	Interpretation
Satisfied	3	Evidence supports the selected control expectation without a material gap.
Partially supported	4	Control activity exists, but evidence, consistency, or closure is incomplete.
Not supported	1	Case-study evidence does not support the expected control operation.

4. Control assessment detail Back to TOC

Control	Area	Status	Assessment conclusion	Methods
AC-2	Account management	Satisfied	Requests and role changes use a ticket workflow with named approvals. Sample records show complete approval fields.	Examine, Interview
AC-6	Least privilege	Satisfied	Standard role groups separate administrators, compliance editors, report viewers, and read-only users.	Examine
IA-2	Identification and authentication	Partially supported	Standard users authenticate through enterprise SSO with MFA. Break-glass privileged access does not have a repeatable approval and MFA evidence package.	Examine, Test
AU-6	Audit record review	Partially supported	Logs are generated and retained centrally. Weekly review is expected, but the sample period contains missed or incomplete review records.	Examine, Interview
CM-2	Baseline configuration	Satisfied	A current baseline exists for the TRACER application and core components.	Examine
RA-5	Vulnerability monitoring	Partially supported	Scanning occurs, but two high items exceed the internal remediation target without a single consolidated escalation record.	Examine
IR-8	Incident response plan and readiness	Partially supported	Tabletop activity occurred. Corrective actions exist, but closure criteria and proof of completion are not consistently documented.	Examine, Interview
CA-7	Continuous monitoring	Not supported	Monitoring inputs exist, but the case study does not show a recurring consolidated posture review linking open findings, vulnerability status, and remediation decisions.	Examine

5. Formal findings Back to TOC

Finding	Title	Control	Condition	Recommendation
F-01	Privileged break-glass access evidence is incomplete.	IA-2	Repeatable evidence does not show that exception access is consistently approved, authenticated, and reviewed.	Create a break-glass access standard, retain approval records, and validate use during periodic privileged access review.
F-02	Audit log review cadence is not consistently evidenced.	AU-6	Expected weekly review exists in the workflow, but the sample does not support reliable completion or reviewer attribution.	Define minimum review record fields and maintain a complete review trail.
F-03	High vulnerability remediation escalation is fragmented.	RA-5	Scanning occurs, but aged high findings are not represented in a single management escalation path.	Create one remediation tracker with aging, owner, escalation date, and exception rationale.
F-04	Tabletop corrective actions lack closure	IR-3 / IR-8	Tabletop after-action notes identify lessons, but those items are not converted into tracked corrective actions with owners, due dates, and closure evidence.	Route tabletop corrective actions into the POA&M tracker within 5 business days. Assign an owner, due date, and defined closure artifact for each item.
F-05	Continuous monitoring view is incomplete.	CA-7	Open findings, POA&M items, vulnerability backlog, and other monitoring inputs are not consolidated into a recurring system posture review.	Create a concise monthly monitoring summary for the system owner and risk stakeholders that consolidates open items, aging concerns, escalation needs, and remediation status.

6. Limitations and handoff to risk analysis Back to TOC

- This case study does not test a complete control baseline. It shows selected control review and finding development.
- The risk assessment translates the findings into threat scenarios, likelihood, impact, and treatment recommendations.
- The POA&M converts findings into corrective actions with closure evidence and escalation logic.